GRC Case Study: Malicious Android Package (APK) Delivered via Social Engineering

Document Purpose

This case study documents a real security incident handled by the author in their role as a SOC Analyst at an MSSP, reframed through a Governance, Risk, and Compliance (GRC) lens. It demonstrates practical experience translating SOC incident response into control mapping, risk assessment, and compliance documentation — skills directly relevant to a GRC / Information Security Compliance role.

Confidentiality Note

Client-identifying details have been generalized. The organization is referred to as "the Client," an insurance firm operating in the financial sector.

1. Incident Summary

Field	Detail
Incident Type	Malware delivery via disguised file download
Sector	Financial Services (Insurance)
Detection Source	Endpoint Detection and Response (EDR)
Severity	Critical
Date	12 June
Alert Generated	15:44
Alert Triaged	15:46
Endpoint Isolated	15:55
Total Time to Containment	Under 15 minutes
SLA Outcome	No SLA breach

2. Incident Narrative

A user within the Client's organization received and downloaded a file named to resemble a legitimate tax invoice (e.g., "Tax_Invoice.apk"). Believing it to be a routine financial document, the user downloaded and attempted to open the file. The file was in fact a malicious Android Package (APK), a format not typically used for invoicing — itself an early red flag.

The organization's EDR solution generated a critical-severity alert at 15:44. The on-shift SOC Analyst (the author), working independently at the time with no other analyst on shift, triaged the alert within two minutes.

Investigation steps taken:

1. Reviewed full alert details and process/file metadata within the EDR console.
2. Extracted the file hash and submitted it to VirusTotal for reputation analysis.
3. Confirmed malicious verdict: 18 out of 90 vendors flagged the file as malicious.
4. Cross-referenced the user and endpoint context to confirm legitimacy of the account (no signs of prior compromise or anomalous account behavior).
5. Consulted SOC playbook and escalation matrix for critical-severity EDR alerts involving confirmed-malicious files.
6. Raised an incident ticket and initiated client notification per the escalation matrix.
7. Directed the Client's internal IT team to isolate the affected endpoint; isolation was confirmed at 15:55.
8. Malicious file was removed from the device before execution or further action could be confirmed.

No lateral movement, data exfiltration, or further compromise was observed. The incident was contained entirely within SLA, and the analyst received formal appreciation from the account/client team for the response.

3. Control Mapping

Incident Action	ISO 27001 Annex A Control	NIST CSF Function	Notes
User downloaded disguised malicious file	A.6.3 Security awareness, education and training	Protect (PR.AT)	Gap at the user-awareness layer

Incident Action	ISO 27001 Annex A Control	NIST CSF Function	Notes
EDR generated detection alert	A.8.7 Protection against malware; A.8.16 Monitoring activities	Detect (DE.CM)	Technical control performed as designed
Hash verification via VirusTotal	A.8.16 Monitoring activities	Detect (DE.AE)	Analyst-driven threat validation
Escalation matrix / SOC playbook followed	A.5.24 Incident management planning; A.5.26 Response to incidents	Respond (RS.MA, RS.CO)	Documented, repeatable IR process
Client notification	A.5.24; A.5.26	Respond (RS.CO)	Communication within SLA
Endpoint isolation	A.8.16; A.5.26	Respond (RS.MI)	Contained threat before impact
File removal	A.8.7 Protection against malware	Recover (RC.RP)	Eradication step

4. Risk and Impact Assessment

Inherent Risk: High — malware delivered directly to an endpoint in a financial services environment carries high potential impact if executed (ransomware, data exfiltration, credential theft).

Residual Risk (post-incident): Low — effective detection and response contained the file before execution or compromise. No data loss, system compromise, or business disruption resulted.

Control Effectiveness: Technical detection and response controls (EDR, SOC monitoring, escalation procedures) performed effectively. The control gap sits at the human/awareness layer, where a disguised file name was enough to prompt a download.

5. Recommendations for Control Improvement

1. **Security Awareness Training:** Reinforce training on recognizing mismatched file types (invoices should never arrive as .apk files) and sender verification.
2. **Email/Attachment Filtering:** Review the Client's email gateway or attachment-filtering policy to block or sandbox executable and APK file types at the perimeter.

3. **Simulated Phishing Exercises:** Periodic campaigns to measure and improve user susceptibility over time.
4. **Playbook Review:** Maintain and periodically test the escalation matrix so response times stay within SLA even during single-analyst shifts.
5. **Metrics Tracking:** Formally log mean time to detect (MTTD) and mean time to contain (MTTC) to support future control-effectiveness reporting.

6. Conclusion

This incident demonstrates the practical link between SOC-level detection and response activity and GRC-level control assurance. While technical and procedural controls functioned effectively — resulting in zero compromise and no SLA breach — root-cause analysis highlights a control gap at the security awareness layer, addressed in the recommendations above.

GRC Case Study: Targeted Phishing Simulation Against Senior Leadership and Compliance Staff

Document Purpose

This second case study documents a real security incident handled by the author as a SOC Analyst at an MSSP, reframed through a GRC lens. It illustrates incident triage under ambiguity, high-severity escalation handling, and the value of coordinated detection-and-response validation between an MSSP and its client — all directly relevant to GRC and information security compliance work.

Confidentiality Note

Client-identifying details have been generalized. The organization is referred to as "the Client."

1. Incident Summary

Field	Detail
Incident Type	Suspected targeted phishing / credential harvesting campaign

Field	Detail
Detection Source	SIEM (Wazuh)
Severity	Critical (high-profile targets)
Targets	CISO, security team lead, senior SOC engineer, financial fraud investigators, compliance managers
Email Subject Line	"Immediate Password Check Required"
Delivery Action	Allowed (emails reached recipient inboxes)
Outcome	Confirmed internal phishing simulation / awareness campaign run by the Client; no compromise

2. Incident Narrative

At the start of a shift, the analyst (the author) observed multiple SIEM alerts, all originating from the same sender, each targeting a different high-profile recipient within the Client organization. Recipients included the CISO, a security team lead, a senior SOC engineer, and several members of the finance and compliance functions, including financial fraud investigators and compliance managers.

Each email shared a common, highly suggestive subject line: "Immediate Password Check Required," consistent with a credential-harvesting phishing technique designed to direct recipients to a fraudulent login page. The SIEM showed the delivery action for these emails as "allowed," meaning the messages had reached recipient inboxes rather than being quarantined or blocked.

Given the seniority of the targeted individuals and the credential-theft indicators in the message, the analyst treated the activity as critical severity without waiting for further confirmation. Response actions taken:

1. Assessed the alert pattern (same sender, multiple senior/high-value recipients, urgent credential-themed subject line) as consistent with a targeted phishing/credential-harvesting attempt.
2. Followed the escalation matrix and SOC playbook for critical-severity, high-profile-target phishing alerts.
3. Exercised pre-authorized direct escalation to the Client's senior stakeholders, given the severity and seniority of those targeted.
4. Requested the Client confirm whether any recipient had clicked the link or interacted with the email, given that delivery had been allowed.

The Client subsequently confirmed that the activity was part of an internal, multi-day phishing simulation and security awareness campaign, run deliberately without prior notice to the MSSP. The purpose was to validate, from the Client's side, that the service provider's SOC would detect and escalate such activity appropriately without foreknowledge. No actual compromise occurred at any point. The Client expressed satisfaction with the speed and correctness of the response, and the analyst received formal appreciation for the handling of the incident.

3. Control Mapping

Incident Action	ISO 27001 Annex A Control	NIST CSF Function	Notes
SIEM detected pattern across multiple targeted emails	A.8.16 Monitoring activities	Detect (DE.CM, DE.AE)	Correlation across sender/recipients drove early recognition
Analyst assessed severity from indicators alone	A.5.7 Threat intelligence; A.8.16 Monitoring activities	Detect (DE.AE)	Judgment-based triage ahead of explicit confirmation
Escalation matrix / playbook followed for high-profile targets	A.5.24 Incident management planning; A.5.26 Response to incidents	Respond (RS.MA, RS.CO)	Severity scaled correctly to seniority of targets
Direct escalation to senior Client stakeholders	A.5.5 Contact with authorities; A.5.26 Response to incidents	Respond (RS.CO)	Pre-authorized escalation path used appropriately
Client confirmed simulation; no compromise	A.6.3 Security awareness, education and training	Protect (PR.AT)	Validates effectiveness of Client's own awareness program
MSSP response validated by Client without prior notice	A.5.35 Independent review of information security; A.5.26	Respond / Govern (GV.OV)	Acts as an unannounced control-assurance test of the MSSP relationship

4. Risk and Impact Assessment

Inherent Risk: High — phishing targeting senior leadership, security personnel, and compliance/finance staff (a classic "whaling" pattern) carries severe potential impact, including credential compromise of privileged accounts and downstream fraud.

Residual Risk (post-incident): Negligible — the activity was a controlled internal simulation; no credentials were harvested and no systems were compromised.

Control Effectiveness: The incident functioned as a live, unannounced assurance test of the MSSP's detection and escalation capability. The analyst's response — rapid severity assessment, correct escalation path, and proactive outreach to confirm user interaction — met the standard the Client was implicitly testing for, without the MSSP having foreknowledge of the exercise.

5. Recommendations for Control Improvement

1. **Simulation Coordination Protocol:** While the Client intentionally withheld notice to test the MSSP, recommend establishing a documented post-exercise debrief process so simulation outcomes are formally logged for both parties' assurance records.
2. **Delivery Action Review:** Evaluate why these emails had a delivery action of "allowed" rather than being flagged or quarantined by existing email security controls, to confirm whether this was intentional (to support the simulation) or reflects a filtering gap.
3. **Escalation Matrix Validation:** Use this incident as a documented, successful test case of the escalation matrix for high-severity, high-profile-target scenarios.
4. **Recognition in Metrics:** Log this as a positive control-validation event in SOC performance/assurance reporting, distinct from genuine incidents, to demonstrate response readiness to auditors or stakeholders.

6. Conclusion

This incident demonstrates effective triage and escalation under ambiguity: the analyst correctly treated a high-severity-looking phishing pattern targeting senior leadership as critical, without waiting for full confirmation, and followed the correct escalation path. Although the activity turned out to be a Client-run simulation, the response validated both the SOC's detection capability and the Client's own security awareness program, reinforcing trust in the MSSP relationship.